AgePass

Jak udowodnić stronie internetowej, że masz 18+ lat, bez ujawniania kim jesteś

Problem

Obecne rozwiązania

- Podawanie danych osobowych stronom 18+
- Brak realnej weryfikacji (checkboxy)
- Wymuszanie logowania przez e-PUAP
- Ryzyko profilowania i inwigilacji

Czego potrzebujemy

- Weryfikacja wieku BEZ ujawniania tożsamości
- Brak możliwości śledzenia użytkownika
- Prostota użycia (6-cyfrowy kod)
- Odporność na zmowę podmiotów

Architektura trójstronna

Trzy podmioty, z których żaden nie wie wszystkiego

Rząd A

mObywatel

WIE:

Kim jesteś
i ile masz lat

NIE WIE:

Jakiego kodu użyjesz
ani na jakiej stronie

Rząd B

NASK

WIE:

ktoś anonimowy
ma 18+

NIE WIE:

Kim jest
ta osoba

Strona 18+

Odbiorca kodu

WIE:

wpisany kod
jest ważny

NIE WIE:

Kim jest
użytkownik

Jak to działa? 3 proste kroki

1

Weryfikacja wieku

Otwierasz mObywatel. Twój telefon generuje losowy token i chowa go w kryptograficznej kopercie. Rząd A sprawdza Twój wiek i podpisuje kopertę — nie widząc co jest w środku.

2

Pobranie kodu

Wysyłasz podpisany token (bez PESELu!) do Rządu B. NASK weryfikuje podpis, generuje jednorazowy 6-cyfrowy kod ważny 5 minut. Nie wie kim jesteś.

3

Wejście na stronę

Wpisujesz kod na stronie 18+. Strona pyta Rząd B: ważny? Odpowiedź: TAK. Kod spalony. Strona nie zna Twojej tożsamości.

Analogia z koperta i kalka

1. Piszesz tajny numer na kartce
2. Wkładasz kartkę do nieprzezroczystej koperty z kalką w środku
3. Urzędnik (Rząd A) sprawdza Twój dowód, podpisuje kopertę — podpis przechodzi przez kalkę na kartkę, ale urzędnik nie widzi co jest w środku
4. Otwierasz kopertę — masz kartkę z Twoim numerem i podpisem urzędnika
5. Idziesz do drugiego okienka (Rząd B), pokazujesz kartkę. Drugie okienko widzi ważny podpis, wydaje kod — ale nie wie kto stał w pierwszym okienku

4 warstwy ochrony prywatności

Nawet jeśli jedno zabezpieczenie zawiedzie, pozostałe trzymają

1

Separacja prawna

Dwa resorty + ustawowy zakaz wymiany danych. Zmowa = przestępstwo.

PRAWNA

2

Ślepe podpisy RSA

Zaślepiony token =/= odślepiony token. Matematycznie niepowiązalne.

MATEMATYCZNA

3

OPRF

Serwer przetwarza dane, ktorych nigdy nie widział. Nawet logi sa bezużyteczne.

MATEMATYCZNA

4

Enklawy TEE

Intel SGX / ARM TrustZone. Kod open-source. Nawet admin serwera nie widzi danych.

SPRZĘTOWA

Co jesli Rząd A i B zmowią się?

Rząd A ma:	Rząd B ma:
PESEL + zaślepiony token (losowy szum)	Odślepiony token + kod (bez tożsamości)

Zaślepiony token =/= Odślepiony token

To jest sedno ślepego podpisu! Nawet mając OBA dzienniki,
NIE DA SIE powiązać wpisów Rządu A z wpisami Rządu B.

Proof of Concept

Działający kod + interaktywny mockup aplikacji

Kod kryptograficzny (Python)

- Ślepe podpisy RSA (Chaum 1983)
- Nieświadoma Funkcja PRF (OPRF)
- Generowanie liczb pierwszych
- Pełna symulacja 3 podmiotów
- Test: dorosly, nieletni, ponowne użycie
- Zero zewnętrznych bibliotek

Mockup aplikacji (HTML)

- Wygląd jak mObywatel
- Generowanie kodów z timerem 5 min
- 7 kroków kryptografii z analogiami
- Okno strony 18+ do weryfikacji
- Jednorazowe spalanie kodów
- Pełna interakcja w przeglądarce

Podsumowanie

Warstwa	Co gwarantuje	Typ
Separacja prawna	Wymiana danych = przestępstwo	Prawna
Ślepe podpisy RSA	Nie da się powiązać tokenów	Matematyczna
OPRF	Serwer nie widzi danych	Matematyczna
Enklawy TEE	Kod robi to co deklaruje	Sprzętowa
Open-source	Brak ukrytych backdoorow	Społeczna

Żeby deanonimizowac użytkownika, trzeba jednocześnie:
złamać matematykę OPRF + zhackować enklawę sprzętową
+ obejść audyt open-source + złamać prawo

Dziękujemy!

Kod źródłowy + interaktywne demo:

github.com/Inner-Savages/BKIHack2026

https://mobywatel-bkihack.netlify.app/

https://secured-bkihack.netlify.app/

BKIHack 2026 | Inner Savages